

ZAP by Checkmarx

Scanning Report

Generated with  ZAP on Sun 10 May 2026, at 09:43:59

ZAP Version: 2.17.0

ZAP by [Checkmarx](#)

Contents

- [About This Report](#)
 - [Report Parameters](#)
- [Summaries](#)
 - [Alert Counts by Risk and Confidence](#)
 - [Alert Counts by Site and Risk](#)
 - [Alert Counts by Alert Type](#)
 - [Insights](#)
- [Alerts](#)
 - [Risk=High, Confidence=Medium \(2\)](#)
 - [Risk=High, Confidence=Low \(1\)](#)
 - [Risk=Medium, Confidence=High \(1\)](#)
 - [Risk=Medium, Confidence=Low \(1\)](#)

- [Risk=Low, Confidence=High \(1\).](#)
- [Risk=Low, Confidence=Medium \(5\).](#)
- [Risk=Informational, Confidence=Medium \(3\).](#)
- [Risk=Informational, Confidence=Low \(3\).](#)
- [Appendix](#)
 - [Alert Types](#)

About This Report

Report Parameters

Contexts

No contexts were selected, so all contexts were included by default.

Sites

The following sites were included:

- <https://ginandjuice.shop>

(If no sites were selected, all sites were included by default.)

An included site must also be within one of the included contexts for its data to be included in the report.

Risk levels

Included: [High](#), [Medium](#), [Low](#), [Informational](#)

Excluded: None

Confidence levels

Included: [User Confirmed](#), [High](#), [Medium](#), [Low](#)

Excluded: User Confirmed, High, Medium, Low, False Positive

Summaries

Alert Counts by Risk and Confidence

This table shows the number of alerts for each level of risk and confidence included in the report.

(The percentages in brackets represent the count as a percentage of the total number of alerts included in the report, rounded to one decimal place.)

		Confidence				
Risk		User Confirmed	High	Medium	Low	Total
	High	0 (0.0%)	0 (0.0%)	2 (11.8%)	1 (5.9%)	3 (17.6%)
	Medium	0 (0.0%)	1 (5.9%)	0 (0.0%)	1 (5.9%)	2 (11.8%)
	Low	0 (0.0%)	1 (5.9%)	5 (29.4%)	0 (0.0%)	6 (35.3%)
	Informational	0 (0.0%)	0 (0.0%)	3 (17.6%)	3 (17.6%)	6 (35.3%)
	1	0 (0.0%)	0 (0.0%)	3 (17.6%)	3 (17.6%)	6 (35.3%)
Total		0 (0.0%)	2 (11.8%)	10 (58.8%)	5 (29.4%)	17 (100%)

Alert Counts by Site and Risk

This table shows, for each site for which one or more alerts were raised, the number of alerts raised at each risk level.

Alerts with a confidence level of "False Positive" have been excluded from these counts.

(The numbers in brackets are the number of alerts raised for the site at or above that risk level.)

Site	Risk				Informational
	High (= High)	Medium (>= Medium)	Low (>= Low)	Low (>= Low)	
https://ginandjuice.shop	3 (3)	2 (5)	6 (11)	6 (17)	

Alert Counts by Alert Type

This table shows the number of alerts of each alert type, together with the alert type's risk level.

(The percentages in brackets represent each count as a percentage, rounded to one decimal place, of the total number of alerts included in this report.)

Alert type	Risk	Count
Cross Site Scripting_(Reflected)	High	2 (11.8%)
SQL Injection	High	1 (5.9%)
Vulnerable JS Library	High	1 (5.9%)
Absence of Anti-CSRF Tokens	Medium	2 (11.8%)
Total		17

Alert type	Risk	Count
Content Security Policy (CSP) Header Not Set	Medium	5 (29.4%)
Cookie No HttpOnly Flag	Low	5 (29.4%)
Cookie Without Secure Flag	Low	5 (29.4%)
Cookie with SameSite Attribute None	Low	5 (29.4%)
Cookie without SameSite Attribute	Low	5 (29.4%)
Strict-Transport-Security Header Not Set	Low	5 (29.4%)
X-Content-Type-Options Header Missing	Low	5 (29.4%)
Cookie Poisoning	Informational	1 (5.9%)
Information Disclosure - Suspicious Comments	Informational	19 (111.8%)
Modern Web Application	Informational	5 (29.4%)
Re-examine Cache-control Directives	Informational	5 (29.4%)
Session Management Response Identified	Informational	46 (270.6%)
User Controllable HTML Element Attribute (Potential XSS)	Informational	3 (17.6%)
Total		17

Insights

This table shows information that is likely to be very relevant to you, but which is not related to vulnerabilities, or potentially even related to the application in question.

Level	Reason	Site	Description	Statistic
Medium	Exceeded Low		Percentage of memory used	94
Low	Warning		ZAP errors logged - see the zap.log file for details	12
Low	Warning		ZAP warnings logged - see the zap.log file for details	80
Low	Exceeded High	https://ginandjuice.shop	Percentage of slow responses	100 %
Info	Informational	https://ginandjuice.shop	Percentage of responses with status code 2xx	49 %
Info	Informational	https://ginandjuice.shop	Percentage of responses with status code 3xx	1 %
Info	Exceeded Low	https://ginandjuice.shop	Percentage of responses with status code 4xx	47 %
Info	Informational	https://ginan	Percentage of responses with	1 %

Level	Reason	Site	Description	Statistic
		djuice. shop	status code 5xx	
Info	Informat ional	https:// /ginan djuice. shop	Percentage of endpoints with content type application/font- woff	3 %
Info	Informat ional	https:// /ginan djuice. shop	Percentage of endpoints with content type application/javascri pt	10 %
Info	Informat ional	https:// /ginan djuice. shop	Percentage of endpoints with content type application/json	2 %
Info	Informat ional	https:// /ginan djuice. shop	Percentage of endpoints with content type image/gif	1 %
Info	Informat ional	https:// /ginan djuice. shop	Percentage of endpoints with content type image/jpeg	12 %
Info	Informat ional	https:// /ginan djuice. shop	Percentage of endpoints with content type image/png	36 %
Info	Informat ional	https:// /ginan djuice. shop	Percentage of endpoints with content type image/svg+xml	8 %

Level	Reason	Site	Description	Statistic
Info	Informational	https://ginandjuice.shop	Percentage of endpoints with content type image/x-icon	1 %
Info	Informational	https://ginandjuice.shop	Percentage of endpoints with content type text/css	4 %
Info	Informational	https://ginandjuice.shop	Percentage of endpoints with content type text/html	16 %
Info	Informational	https://ginandjuice.shop	Percentage of endpoints with content type video/mp4	1 %
Info	Informational	https://ginandjuice.shop	Percentage of endpoints with method GET	96 %
Info	Informational	https://ginandjuice.shop	Percentage of endpoints with method POST	3 %
Info	Informational	https://ginandjuice.shop	Count of total endpoints	86

Alerts

Risk=High, Confidence=Medium (2)

<https://ginandjuice.shop> (2)

Cross Site Scripting (Reflected) (1)

► POST <https://ginandjuice.shop/login>

Vulnerable JS Library (1)

► GET https://ginandjuice.shop/resources/js/angular_1-7-7.js

Risk=High, Confidence=Low (1)

<https://ginandjuice.shop> (1)

SQL Injection (1)

► GET <https://ginandjuice.shop/catalog?category=%27>

Risk=Medium, Confidence=High (1)

<https://ginandjuice.shop> (1)

Content Security Policy (CSP) Header Not Set (1)

► GET <https://ginandjuice.shop>

Risk=Medium, Confidence=Low (1)

<https://ginandjuice.shop> (1)

Absence of Anti-CSRF Tokens (1)

► GET <https://ginandjuice.shop/catalog/product?productId=1>

Risk=Low, Confidence=High (1)

<https://ginandjuice.shop> (1)

Strict-Transport-Security Header Not Set (1)

► GET <https://ginandjuice.shop>

Risk=Low, Confidence=Medium (5)

<https://ginandjuice.shop> (5)

Cookie No HttpOnly Flag (1)

► GET <https://ginandjuice.shop>

Cookie Without Secure Flag (1)

► GET <https://ginandjuice.shop>

Cookie with SameSite Attribute None (1)

► GET <https://ginandjuice.shop>

Cookie without SameSite Attribute (1)

► GET <https://ginandjuice.shop>

X-Content-Type-Options Header Missing (1)

► GET <https://ginandjuice.shop>

Risk=Informational, Confidence=Medium (3)

<https://ginandjuice.shop> (3)

Information Disclosure - Suspicious Comments (1)

- ▶ GET https://ginandjuice.shop/resources/footer/js/scanme.js

Modern Web Application (1)

- ▶ GET https://ginandjuice.shop

Session Management Response Identified (1)

- ▶ GET https://ginandjuice.shop

Risk=Informational, Confidence=Low (3)

https://ginandjuice.shop (3)

Cookie Poisoning (1)

- ▶ GET https://ginandjuice.shop/catalog?category=Accessories

Re-examine Cache-control Directives (1)

- ▶ GET https://ginandjuice.shop

User Controllable HTML Element Attribute (Potential XSS) (1)

- ▶ GET https://ginandjuice.shop/blog/?back=https%3A%2F%2Fzap.example.com&search=ZAP

Appendix

Alert Types

This section contains additional information on the types of alerts in the report.

Cross Site Scripting (Reflected)

Source	raised by an active scanner (Cross Site Scripting_(Reflected))
CWE ID	79
WASC ID	8
Reference	▪ https://owasp.org/www-community/attacks/xss/ ▪ https://cwe.mitre.org/data/definitions/79.html

SQL Injection

Source	raised by an active scanner (SQL Injection)
CWE ID	89
WASC ID	19
Reference	▪ https://cheatsheetseries.owasp.org/cheatsheets/SQL_Injection_Prevention_Cheat_Sheet.html

Vulnerable JS Library

Source	raised by a passive scanner (Vulnerable JS Library (Powered by Retire.js))
CWE ID	1395
Reference	▪ https://owasp.org/Top10/A06_2021-Vulnerable_and_Outdated_Components/

Absence of Anti-CSRF Tokens

Source	raised by a passive scanner (Absence of Anti-CSRF Tokens)
CWE ID	352
WASC ID	9
Reference	■ https://cheatsheetseries.owasp.org/cheatsheets/Cross-Site_Request_Forgery_Prevention_Cheat_Sheet.html ■ https://cwe.mitre.org/data/definitions/352.html

Content Security Policy (CSP) Header Not Set

Source	raised by a passive scanner (Content Security Policy (CSP) Header Not Set)
CWE ID	693
WASC ID	15
Reference	■ https://developer.mozilla.org/en-US/docs/Web/HTTP/Guides/CSP ■ https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html ■ https://www.w3.org/TR/CSP/ ■ https://w3c.github.io/webappsec-csp/ ■ https://web.dev/articles/csp ■ https://caniuse.com/#feat=contentsecuritypoli

[cy](#)

- <https://content-security-policy.com/>

Cookie No HttpOnly Flag

Source	raised by a passive scanner (Cookie No HttpOnly Flag)
CWE ID	1004
WASC ID	13
Reference	▪ https://owasp.org/www-community/HttpOnly

Cookie Without Secure Flag

Source	raised by a passive scanner (Cookie Without Secure Flag)
CWE ID	614
WASC ID	13
Reference	▪ https://owasp.org/www-project-web-security-testing-guide/v41/4-Web_Application_Security_Testing/06-Session_Management_Testing/02-Testing_for_Cookies_Attributes.html

Cookie with SameSite Attribute None

Source	raised by a passive scanner (Cookie without SameSite Attribute)
CWE ID	1275
WASC ID	13

Reference

- <https://datatracker.ietf.org/doc/html/draft-ietf-httpbis-cookie-same-site>

Cookie without SameSite Attribute**Source**

raised by a passive scanner ([Cookie without SameSite Attribute](#))

CWE ID

[1275](#)

WASC ID

13

Reference

- <https://datatracker.ietf.org/doc/html/draft-ietf-httpbis-cookie-same-site>

Strict-Transport-Security Header Not Set**Source**

raised by a passive scanner ([Strict-Transport-Security Header](#))

CWE ID

[319](#)

WASC ID

15

Reference

- https://cheatsheetseries.owasp.org/cheatsheets/HTTP_Strict_Transport_Security_Cheat_Sheet.html
- <https://owasp.org/www-community/Security-Headers>
- https://en.wikipedia.org/wiki/HTTP_Strict_Transport_Security
- <https://caniuse.com/stricttransportsecurity>
- <https://datatracker.ietf.org/doc/html/rfc6797>

X-Content-Type-Options Header Missing

Source	raised by a passive scanner (X-Content-Type-Options Header Missing)
CWE ID	693
WASC ID	15
Reference	▪ https://learn.microsoft.com/en-us/previous-versions/windows/internet-explorer/ie-developer/compatibility/gg622941(v=vs.85) ▪ https://owasp.org/www-community/Security-Headers

Cookie Poisoning

Source	raised by a passive scanner (Cookie Poisoning)
CWE ID	565
WASC ID	20
Reference	▪ https://en.wikipedia.org/wiki/HTTP_cookie ▪ https://cwe.mitre.org/data/definitions/565.html

Information Disclosure - Suspicious Comments

Source	raised by a passive scanner (Information Disclosure - Suspicious Comments)
CWE ID	615
WASC ID	13

Modern Web Application

Source raised by a passive scanner ([Modern Web Application](#))

Re-examine Cache-control Directives

Source raised by a passive scanner ([Re-examine Cache-control Directives](#))

CWE ID [525](#)

WASC ID 13

Reference

- https://cheatsheetseries.owasp.org/cheatsheets/Session_Management_Cheat_Sheet.html#web-content-caching
- <https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Cache-Control>
- <https://grayduck.mn/2021/09/13/cache-control-recommendations/>

Session Management Response Identified

Source raised by a passive scanner ([Session Management Response Identified](#))

Reference

- <https://www.zaproxy.org/docs/desktop/addons/authentication-helper/session-mgmt-id/>

User Controllable HTML Element Attribute (Potential XSS)

Source raised by a passive scanner ([User Controllable HTML Element Attribute \(Potential XSS\)](#))

CWE ID [20](#)

WASC ID

20

Reference

■ https://cheatsheetseries.owasp.org/cheatsheets/Input_Validation_Cheat_Sheet.html